

BEFORE Placeholder

AFTER

# Trigger Events & Reassessment Standard (Out-of-Cycle Reviews)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: \_\_\_\_\_

Review cadence (this document): Annually

## 1. Purpose

This document defines trigger events that require an out-of-cycle third-party security reassessment, regardless of the standard review cadence.

## 2. Principle

If a trigger event changes the supplier's exposure (data, access, connectivity, criticality, sub-processors), the supplier **MUST** be reassessed and, where appropriate:

- re-tiered (Critical / Important / Low),
- re-issued an evidence pack (full or targeted),
- revalidated against minimum requirements,
- issued conditions and/or exceptions, or
- subject to a decision to restrict scope or offboard.

## 3. Trigger events (mandatory reassessment)

### 3.1 Scope and data changes

Mandatory reassessment when:

- new data types are introduced (especially personal data, financial data, authentication secrets)
- data volume increases materially (e.g., small pilot → broad rollout)
- data residency/processing locations change
- supplier begins storing data previously not stored (e.g., logging, support tickets, backups)

Minimum actions:

- confirm tier remains correct
- engage DPO/Privacy Officer if personal data scope changes
- update DPA/privacy terms if required

## 3.2 Access and privilege changes

Mandatory reassessment when:

- any privileged/admin access is requested or expanded
- support model changes to include interactive remote access
- new service accounts are created or permissions broadened
- supplier requests production access where previously non-production only

Minimum actions:

- apply privileged access requirements (brokered access preferred)
- validate access controls and auditability prior to granting access
- consider tier-up to Critical if not already

## 3.3 Integration and connectivity changes

Mandatory reassessment when:

- new integration pattern is introduced (API, agent/collector, file transfer, email relay)
- API permissions expand from read → write, or scope increases materially
- persistent connectivity is introduced (VPN/private link) or inbound connectivity requested

- network rules/allowlists are expanded materially
- secrets/certificates are reissued or integration identity model changes

Minimum actions:

- require integration pattern review with IT/Platform Owner
- validate key management/rotation and least privilege scopes
- confirm logging requirements remain met

### 3.4 Supplier incidents and threat activity

Mandatory reassessment when:

- supplier notifies a security incident/breach impacting service scope
- credible intelligence indicates supplier compromise relevant to service scope
- repeated security events indicate systemic weakness

Minimum actions:

- initiate incident-triggered review playbook
- assess impact to data/access/integration
- confirm containment, remediation plan, and monitoring enhancements
- consider scope restriction, conditions, or offboarding decision

### 3.5 Control posture degradation

Mandatory reassessment when:

- supplier loses a material assurance artifact (e.g., certification lapse) without acceptable replacement evidence
- supplier refuses or cannot meet baseline requirements previously met
- supplier materially changes security operations model (e.g., outsources SOC, reduces monitoring)

Minimum actions:

- targeted evidence refresh
- update gap log and remediation plan
- raise exception if MUST requirements are impacted

### 3.6 Sub-processor / fourth-party changes

Mandatory reassessment when:

- new material sub-processor is introduced
- sub-processor locations/residency change materially
- supplier cannot provide updated sub-processor list or change notifications
- supplier's outsourcing chain becomes opaque for material components

Minimum actions:

- DPO/Privacy Officer review if personal data involved
- reassess tier (often tier-up)
- confirm contractual commitments for notifications and flow-down controls

### 3.7 Business criticality and service changes

Mandatory reassessment when:

- supplier service becomes business critical (supports a critical business service or regulatory reporting)
- organisation changes service dependency (e.g., becomes sole provider)
- major changes to business process increase reliance on supplier

Minimum actions:

- reassess tier to Critical where applicable
- ensure resilience requirements and evidence are in place

### 3.8 Contractual events

Mandatory reassessment when:

- contract renewal (Critical suppliers always; others if earlier than cadence)
- material contract changes affecting security/privacy obligations
- supplier proposes limiting audit rights, incident notification, or sub-processor transparency

Minimum actions:

- rerun minimum requirement check for impacted areas
- escalate per governance for any reduction in commitments

### 3.9 Organisational or supplier change events

Mandatory reassessment when:

- supplier merger/acquisition, divestment, or major ownership change
- supplier changes hosting model (e.g., moves cloud provider)
- material organisational architecture change that alters integration/security controls

Minimum actions:

- revalidate controls and assurance evidence relevant to changes
- update integration pattern if needed

## 4. Trigger severity and response time

### Severity 1 (Immediate)

Examples:

- supplier breach impacting in-scope data
- inbound connectivity requested for a Critical service
- privileged production access expansion

Response:

- reassessment initiated within 2 business days
- temporary controls/scope restriction considered until validated

## Severity 2 (Planned, time-bound)

Examples:

- new integration type introduced
- material data volume increase
- sub-processor change affecting data residency

Response:

- reassessment initiated within 5 business days or before change goes live (whichever is sooner)

## Severity 3 (Administrative)

Examples:

- contact detail changes, minor non-security contract changes

Response:

- update records within 10 business days

## 5. Reassessment outputs (minimum)

A trigger-event reassessment MUST produce:

- updated scope statement
- tier confirmation or change (with rationale)
- targeted evidence request and review outcomes
- updated gap log and actions
- exceptions (if required) with expiry and compensating controls
- decision record (approve/conditional/restrict/offboard planning)

## 6. Notification and ownership

- Business Service Owner MUST notify the program of trigger events they become aware of.
- Procurement MUST notify the program of renewals and material contract changes.
- IT/Platform Owner MUST notify the program of integration/connectivity changes.
- DPO/Privacy Officer MUST be notified of personal data scope/residency changes.

## 7. Record keeping

Trigger events, reassessments, decisions, and evidence MUST be retained according to the program data retention policy.